[Nome da Instituição]
Programa de Mestrado em [Área do Mestrado]

VULNERABILIDADES EM REDES IOT E O IMPACTO DA INJEÇÃO DE DADOS FALSOS (FDI) VIA MQTT EM MALHAS DE CONTROLE

Miguel José Abdala Ribeiro

Relatório técnico submetido como parte dos requisitos de avaliação da disciplina de Internet das Coisas e Redes Veiculares (TP-546).

Docente: Prof. Dr. Samuel Baraldi Mafra

Santa Rita do Sapucaí - MG
2026

1 Introdução

A evolução dos sistemas embarcados e a conectividade propiciaram o surgimento da Internet das Coisas (IoT). Nesse paradigma, dispositivos físicos equipados com sensores, atuadores e capacidade computacional comunicam-se de forma autônoma para monitorar e alterar o estado do ambiente físico. A transição do processamento centralizado na nuvem para a computação de borda (*Edge Computing*) permitiu respostas de baixíssima latência, fundamentais para a automação industrial (IIoT), robótica e cidades inteligentes.

Apesar dos benefícios proporcionados pela IoT, a grande quantidade de dispositivos conectados também aumenta a superfície de ataque das redes[. Muitos dispositivos possuem recursos limitados de processamento, memória e energia, o que dificulta a utilização de mecanismos de segurança sofisticados. Dispositivos restritos são formalmente classificados em categorias, como a Classe 0 (com menos de 10 KB de RAM e 100 KB de Flash), os quais são incapazes de executar abordagens de segurança pesadas, como protocolos tradicionais de transporte seguro. Além disso, problemas como credenciais fracas, software desatualizado e serviços de rede desnecessários facilitam o comprometimento da arquitetura.

A heterogeneidade de hardware, a falta de padronização, a implementação de protocolos de comunicação voltados exclusivamente para a eficiência energética em detrimento da segurança, e o vasto tempo de vida útil de dispositivos legados impossibilitados de receber atualizações dinâmicas (*Over-The-Air*) compõem um cenário desafiador. Fatores como a falta de conscientização sobre segurança frequentemente levam desenvolvedores a priorizarem funcionalidades em detrimento da proteção, resultando em dispositivos que transmitem dados sem criptografia. Este trabalho acadêmico tem como objetivo fornecer um levantamento sobre os vetores de ataque comuns em arquiteturas IoT, seguido por uma análise profunda sobre ataques de Injeção de Dados Falsos no protocolo MQTT e as contramedidas técnicas necessárias para mitigar tais ameaças.

2 O Protocolo MQTT e suas Restrições de Segurança

O protocolo MQTT (*Message Queuing Telemetry Transport*) tornou-se o padrão *de facto* na indústria IoT devido à sua leveza, baixo *overhead* de cabeçalho e arquitetura baseada em publicação e subscrição (*Publish/Subscribe*) operando sobre o protocolo TCP. Nele, os dispositivos (clientes) não se comunicam diretamente entre si, mas através de um nó central denominado *Broker*. O cliente publica mensagens em "tópicos", e outros clientes interessados assinam esses tópicos para receber as atualizações em tempo real.

O MQTT foi projetado visando a eficiência em redes intermitentes e em microcontroladores com recursos escassos de memória e processamento. Por consequência, a especificação padrão do MQTT (na porta oficial 1883 da IANA) não provê autenticação robusta nativa e não implementa criptografia de dados em trânsito. A ausência de proteção por padrão transforma a privacidade dos dados, a autenticação e a integridade da informação em problemas severos nas implementações de MQTT.

Essa característica faz com que qualquer agente mal-intencionado com acesso à rede possa ler passivamente todos os dados da operação em texto claro e deduzir a topologia da planta industrial e as lógicas de automação em funcionamento. Contudo, o impacto mais grave ocorre quando o invasor decide assumir uma postura ativa, explorando a falta de integridade criptográfica.

3 Ataque Específico: Injeção de Dados Falsos (FDI) em Malhas de Controle

Em sistemas de controle de tempo real baseados em IoT, um dispositivo de borda (por exemplo, um controlador PID rodando em um *gateway* industrial) executa um algoritmo para estabilizar um processo físico. O problema escolhido para análise é o ataque de **Injeção de Dados Falsos** (FDI - *False Data Injection*) contra a infraestrutura MQTT que alimenta esses controladores. O FDI consiste na introdução premeditada e forjada de dados no fluxo de comunicação, visando enganar os mecanismos de tomada de decisão da malha de controle.

Sistemas de controle robustos frequentemente empregam detectores de falha (como o detector estatístico χ^2) que calculam o resíduo da medição, ou seja, a diferença entre a leitura observada do sensor e a estimativa prevista pelo modelo do sistema (como um Filtro de Kalman). Medições anormais que geram um resíduo muito grande disparam alarmes imediatos. O grande perigo do ataque FDI moderno é que um invasor inteligente, conhecendo a matriz de dinâmica do sistema, pode projetar matematicamente a sua injeção de dados falsos. O invasor manipula as leituras de modo a alterar o estado estimado do sistema de controle, mantendo o resíduo abaixo dos limiares de segurança, conseguindo assim contornar e enganar o detector de falhas.

3.1 Dinâmica e Execução do Ataque

A execução de um ataque sobre MQTT pode ocorrer tanto em redes públicas quanto locais, explorando vetores distintos:

- **Reconhecimento em Redes Públicas:** Atacantes utilizam motores de busca voltados para a Internet das Coisas, como o Shodan, para mapear globalmente *Brokers* MQTT expostos sem mecanismos de autenticação na porta 1883.
- **Reconhecimento e Interceptação Local:** Quando o atacante já está na mesma rede dos dispositivos IoT, ele realiza a interceptação por meio de envenenamento de rede (*ARP Spoofing*), forçando as tabelas de roteamento a enviarem os pacotes para a sua máquina antes do destino original.
- **Quebra de Integridade e Injeção:** Ao interceptar a comunicação MQTT em texto claro, o atacante manipula os dados em trânsito antes de repassá-los. O invasor pode filtrar pacotes direcionados a um tópico específico e substituir seus valores ou até mesmo alterar o nome do tópico no cabeçalho do MQTT.
- **Criação de Botnets via MQTT:** Um *Broker* desprotegido pode ser cooptado por um *BotMaster* (operador do ataque) para atuar como um servidor de Comando e Controle (C2). O *BotMaster* publica comandos maliciosos em um tópico específico; os dispositivos IoT infectados (a *botnet*), que assinam esse tópico, recebem as instruções simultaneamente para executar ações como ataques massivos de Negação de Serviço Distribuída (DDoS).

3.2 Impacto Físico nos Atuadores

O impacto de uma injeção de dados falsos reflete-se diretamente no comportamento dos atuadores mecânicos. Ao receber uma leitura corrompida que indica um falso desvio

massivo do estado desejado, a lógica de controle tenta compensar esse erro imaginário de maneira instantânea e agressiva.

Essa resposta forçada leva o sistema a enviar comandos de saturação para os atuadores. Válvulas podem fechar bruscamente, servo-motores podem acelerar além de seus limites operacionais seguros e braços robóticos podem colidir contra barreiras físicas. Fisicamente, o controlador é induzido a destruir ou desestabilizar a própria planta que foi programado para proteger, operando sob uma alucinação de dados provocada pela intrusão não detectada.

4 Medidas de Mitigação e Segurança Aplicada

A correção estrutural de vulnerabilidades em redes IoT exige a adoção do princípio do Privilégio Mínimo e da Defesa em Profundidade, adaptando os protocolos criptográficos às realidades do hardware de borda. A ofuscação de portas (como rodar o *Broker* na porta 1884 em vez da 1883) é ineficaz, pois invasores podem identificar os pacotes analisando o cabeçalho do protocolo MQTT na rede.

4.1 Implementação de Criptografia em Trânsito (MQTTS) e mTLS

A transição para o MQTTS (MQTT sobre TLS), utilizando a porta 8883, provê confidencialidade dos dados e integridade estrutural das mensagens. Em redes corporativas de automação, a autenticação mútua (mTLS) é exigida. Neste arranjo, tanto o *Broker* quanto o cliente IoT apresentam certificados digitais X.509 durante o *handshake*. Contudo, o TLS exige grande poder computacional e uso intensivo de rede. Para dispositivos da Classe 0 ou sistemas legados, o uso de co-processadores criptográficos de hardware torna-se um requisito para não inviabilizar a latência da malha de controle.

4.2 Alternativas Leves: ECC e Criptografia Baseada em Atributos (ABE)

Como o TLS pode ser proibitivo para nós sensores de baixíssimo consumo, a literatura acadêmica propõe mecanismos de segurança diretos na camada de aplicação. Uma solução viável é a adoção de Criptografia de Curvas Elípticas (ECC - *Elliptic Curve Cryptography*), que exige chaves significativamente menores para fornecer um nível de segurança equivalente às abordagens tradicionais.

Para arquiteturas do tipo *Publish/Subscribe*, a **Criptografia Baseada em Atributos (ABE - *Attribute-Based Encryption*)** permite que os dados do MQTT sejam criptografados de acordo com uma política de acesso definida por atributos organizacionais (por exemplo, apenas dispositivos com o atributo "$Controlador_Zona_A$" conseguem descriptografar a telemetria). Isso elimina a necessidade de gerenciamento individual de chaves e certificados por sessão para milhares de dispositivos, oferecendo escalabilidade.

4.3 Listas de Controle de Acesso Restritivas (ACLs) e Segmentação

Mesmo com a rede criptografada, a infraestrutura deve prever o comprometimento físico de um nó legítimo. A implementação de ACLs no *Broker* garante privilégios mínimos. Um sensor deve ter permissão **apenas** de publicação em seu próprio tópico de

telemetria, não podendo publicar comandos de atuação. Adicionalmente, utilizando técnicas de segmentação lógica (VLANs) e conteinerização isolada de *gateways* industriais, o tráfego do domínio operacional (OT) deve ser isolado. O tráfego MQTT deve transitar internamente em redes virtuais estritas (*bridge networks*), mitigando o movimento lateral de atacantes e a propagação de *botnets*.

5 Conclusão

A Internet das Coisas representa uma quebra de paradigma na computação distribuída. No entanto, a incorporação de capacidades de atuação física exige um tratamento não-opcional no que tange à cibersegurança.

A exploração do protocolo MQTT por meio da Injeção de Dados Falsos comprova como a simplicidade dos protocolos IoT pode ser punitiva em malhas de controle, destruindo a confiabilidade dos algoritmos através da quebra de integridade dos dados, sendo capaz inclusive de contornar detectores de anomalias e transformar dispositivos passivos em vetores de botnets. A resolução exige a aplicação sistemática de segurança ancorada no MQTTS com mTLS para hardwares capazes, ou protocolos adaptados de Curvas Elípticas e ABE para dispositivos restritos, além de políticas granulares de acesso na infraestrutura. Ao incorporar essas defesas (*Security by Design*), acadêmicos e profissionais garantem um controle resiliente e imune à interceptação.

Referências Bibliográficas

[1] ALABA, F. A. et al. *Internet of Things security: A survey*. Journal of Network and Computer Applications, v. 88, p. 10-28, Elsevier, 2017.

[2] ANDY, S.; RAHARDJO, B.; HANINDHITO, B. *Attack scenarios and security analysis of MQTT communication protocol in IoT system*. In: 2017 4th International Conference on Electrical Engineering, Computer Science and Informatics (EECSI). IEEE, 2017. p. 1-6.

[3] LANGNER, R. *Stuxnet: Dissecting a cyberwarfare weapon*. IEEE Security & Privacy, v. 9, n. 3, p. 49-51, IEEE, 2011.

[4] MO, Y.; SINOPOLI, B. *False data injection attacks in control systems*. In: First Workshop on Secure Control Systems (CPSWEEK). 2010.

[5] SINGH, M. et al. *Secure MQTT for Internet of Things (IoT)*. In: 2015 Fifth International Conference on Communication Systems and Network Technologies. IEEE, 2015. p. 746-751.